



취약점 스캐너

취약점 관리의 핵심 — 올바른 구성과 배포로 신뢰할 수 있는 데이터를 확보하세요.

3장

취약점 스캐너의 역할

정보 수집

지정된 모든 장치의 OS 및 실행 중인 서비스에 대한 정보를 수집합니다.

취약점 판단

수집된 정보를 바탕으로 알려진 취약점에 취약한지 여부를 판단합니다.

보고서 생성

호스트 목록, 각 호스트 정보, 존재하는 취약점을 포함한 보고서를 생성합니다.



스캐너는 어떻게 작동할까요?



스캐너는 대상의 IP 주소로 핑 패킷을 보내 활성 장치를 확인한 후, 열린 포트에 연결하고 서비스 버전을 확인합니다. 탐지 강도를 조절할 수 있으며, 강도가 높을수록 수천 개의 패킷을 전송합니다. 버전 정보를 취약점 DB와 대조하여 취약점을 보고합니다.

오탐: 스캔의 불가피한 한계



왜 오탐이 발생하나요?

공급업체가 취약점 패치를 백포팅한 경우, 스캐너는 이를 알 수 없어 취약하다고 오탐합니다.
OS 지문 인식 오류도 발생할 수 있습니다.

① 오탐을 최소화할 수는 있지만, 네트워크 취약점 스캔의 불가피한 부분입니다.

스캐너 배포: 접근 권한 확보

방식 1 — 모든 액세스 권한 열기

스캐너 트래픽을 허용하도록 네트워크를 구성하면 단일 스캐너로 모든 세그먼트 스캔 가능. 비용 절감 효과 있지만, 공격자가 스캐너를 탈취할 경우 위험.

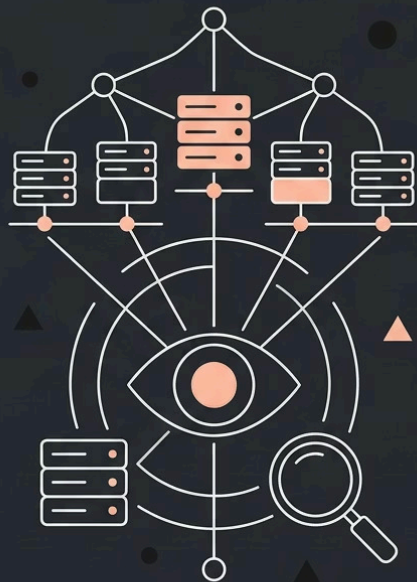
방식 2 — 여러 스캐너 배치

각 네트워크 세그먼트 근처에 스캐너 배치 (예: DMZ 내부). 방화벽 포트 개방 불필요하지만, 하드웨어·라이선스 비용 증가 및 중앙 관리 복잡성 발생.

검색 제한 vs 무제한?



제한 검색:
공격자 관점 모방
방화벽/ACL 차단 존중
현실적 위협 모델

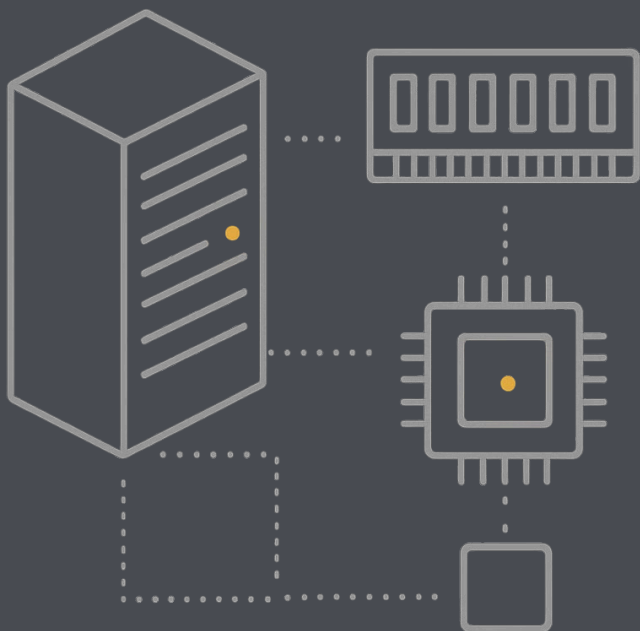


무제한 검색: 기업 전체
취약점 완전 파악
모든 서브넷 가시성 확보
내부 침해 시나리오 포함

왜 무제한이 필요한가?

스캔은 공격자의 관점을 흉내 내기 위한 것이 아닙니다. **기업 전체의 취약점을 완벽하게 파악하는 것이 목표입니다.**

공격자가 이미 제한된 네트워크를 침탈했다면? 스캐너는 모든 시스템을 볼 수 있어야 합니다.



OS·하드웨어 선택 및 스캐너 설정



하드웨어 사양

소규모 환경 기준 CPU 2개 + RAM 8GB 권장. RAM 부족 시 시스템 응답 저하. 빠른 인터넷 연결 필수.



정책 테스트

테스트 네트워크에서 스캔 정책을 먼저 구성·실행. 네트워크 혼잡·장치 오작동 문제가 해결될 때까지 조정.



스캔 일정

작은 단위로 나누어 실행. 업무 시간 외 VLAN, 데이터센터 피크 시간 고려. 이 해관계자 사전 동의 필수.

스캔 계획 수립 시 주의사항

1

이해관계자 참여

스캔 계획 초기부터 관련 팀을 참여시켜
도메인 컨트롤러 다운 같은 사고를 예방하
세요.

2

수동 검사 옵션

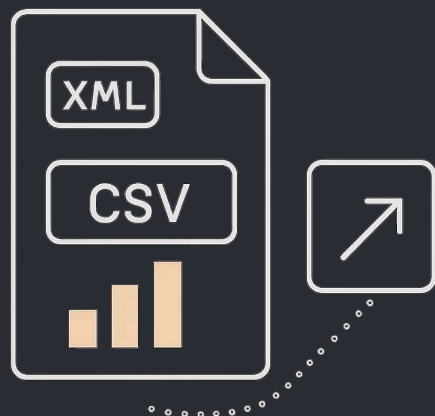
정기 자동 검사를 허용하지 않는 조직은
분석가가 현장에서 수동으로 실행하고 모
니터링.

3

이중화 시스템 활용

가동 시간 요구가 엄격한 조직은 연구실·
이중화 시스템을 스캔 대상으로 사용 가
능. 단, 패치 수준 동기화 어려움.

결과 얻기



보고서 형식

스캐너는 다양한 형식으로 결과를 보고합니다:

- 기계 판독 가능: XML, CSV – 분석 및 자동화에 적합
- 읽기 쉬운 형식: HTML, PDF, Word – 직접 보고서 열람용

스캐너 실행과 결과 수집은 첫 단계일 뿐입니다. **유용한 취약점 정보를 얻으려면 데이터를 분석해야 합니다.**



요약 및 핵심 교훈

적절한 배포

환경에 따라 단일 또는 복수 스캐너를 선택하고, 모든 시스템에 대한 가시성을 확보하세요.

신중한 구성

테스트 환경에서 정책을 검증하고, 오탐을 인지한 채 결과를 분석하세요.

협력적 계획

이해관계자를 초기부터 참여시켜 스캔 오류 발생 시 책임을 분산하세요.